

11. 云计算安全

冯奕
2026



南京大學
NANJING UNIVERSITY

0 引言

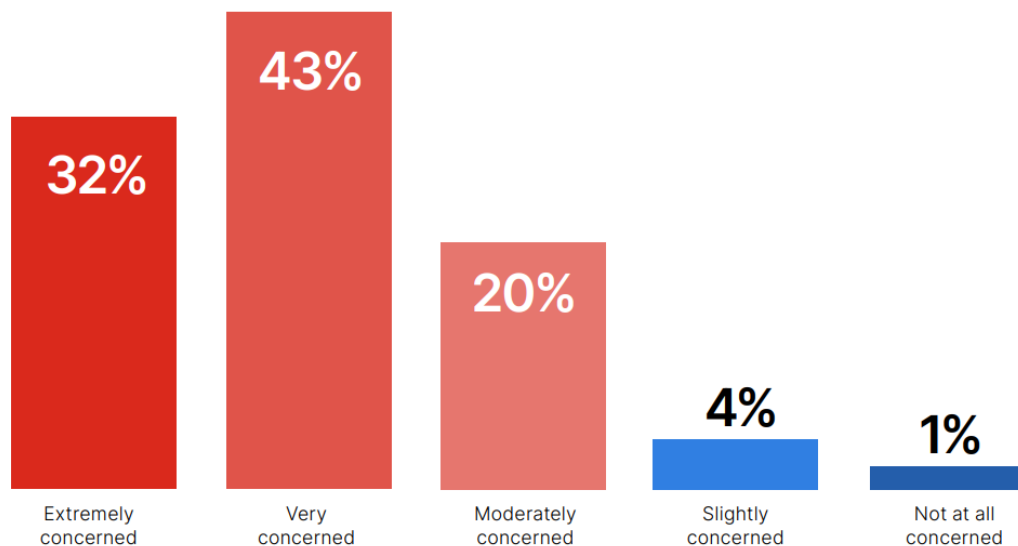
近年来，各种形态（如IaaS，PaaS和SaaS）的云计算蓬勃发展，极大地促进了IT产业的繁荣与信息化社会的发展。

云计算既因其在易用性和经济性方面的特征而在竞争中取得了优势，却又因为其引入的一系列技术特性而面临着全新的安全威胁。



95%

of organizations are moderately to extremely concerned about cloud security



0 引言

TOP 12 cloud computing threats according to Cloud Security Alliance (CSA)

1. Data leakage
2. Insufficient identity management, login information and access management
3. Unsecured interface and API
4. System vulnerability
5. Account theft
6. Insider threat
7. Advanced Persistent Threat
8. Data loss
9. Insufficient Due Diligence
10. Misuse, criminal use of cloud services
11. Denial of Service
12. Shared technology vulnerability



从以下4个方面对当前云计算遇到的安全问题进行分析：

数据存储与计算安全问题；虚拟化安全问题；网络安全问题；访问控制问题；

参考文献如下：

[1] Ashish Singh and Kakali Chatterjee. 2017. Cloud security issues and challenges: A survey. Journal of Network and Computer Applications 79, (2017), 88–115. DOI: <https://doi.org/https://doi.org/10.1016/j.inca.2016.11.027>

[2] DevSecOps实战 / 周纪海等著 .—— 北京：机械工业出版社，2022.1 ISBN 978-7-111-69565-3 2022年1月第1版第1次印刷

[3] <https://www.cybersecurity-insiders.com/portfolio/cloud-security-report-prospectus/>

[4] https://www.pwc.com/cz/cs/cyberandprivacy/Cloud%20security%20report_EN.pdf

1 数据存储与计算安全问题

关于阿里云香港Region可用区C服务中断事件的说明

北京时间2022年12月18日，阿里云香港Region可用区C发生大规模服务中断事件。经过复盘，我们在这里向大家进一步说明故障情况、问题分析和改进措施。

处理过程

12月18日08:56，阿里云监控到香港Region可用区C机房包间通道温警告警，阿里云工程师介入应急处理，通知机房服务商进行现场排查。09:01，阿里云监控到该机房多个包间温升告警，此时工程师排查到冷机异常。09:09，机房服务商按应急预案对异常冷机进行4+4主备切换以及重启，但操作失败，冷水机组无法恢复正常。09:17，依照故障处理流程，启动制冷异常应急预案，进行辅助散热和应急通风。尝试对冷机控制系统逐个进行隔离和手工恢复操作，但发现无法稳定运行，联系冷机设备供应商到现场排查。此时，由于高温原因，部分服务器开始受到影响。

自10:30开始，为避免可能出现的高温消防问题，阿里云工程师陆续对整个机房计算、存储、网络、数据库、大数据集群进行降载处理。期间，继续多次对冷机设备进行操作，但均不能保持稳定运行。

12:30，冷机设备供应商到场，在多方工程师诊断下，对冷塔、冷却水管路及冷机冷凝器进行手工补水排气操作，但系统仍然无法保持稳定运行。阿里云工程师对部分高温包间启动服务器关机操作。14:47，冷机设备供应商对设备问题排查遇到困难，其中一个包间因高温触发了强制消防喷淋。15:20，经冷机设备商工程师现场手工调整配置，冷机群控解锁完成并独立运行，第1台冷机恢复正常，温度开始下降。工程师随后继续通过相同方法对其他冷机进行操作。18:55，4台冷机恢复到正常制冷量。19:02，分批启动服务器，并持续观察温升情况。19:47，机房温度趋于稳定。同时，阿里云工程师开始进行服务启动恢复，并进行必要的数据库完整性检查。

21:36，大部分机房包间服务器陆续启动并完成检查，机房温度稳定。其中一个包间因消防喷淋启动，未进行服务器上电。因为保持数据的完整性至关重要，工程师对这个包间的服务器进行了仔细的数据安全检查，这里花费了一些必要的时间。22:50，数据检查以及风险评估完成，最后一个包间依据安全性逐步进行供电恢复和服务器启动。

服务影响

12月18日09:23，香港Region可用区C部分ECS服务器开始出现停机，触发同可用区内宕机迁移。随着温度继续升高，受影响的服务器停机数量持续增加，客户业务开始受到影响，影响面扩大到香港可用区C的EBS、OSS、RDS等更多云服务。

1 数据存储与计算安全问题

腾讯云官网控制台相关服务异常故障公告

尊敬的客户：

您好！腾讯云官网控制台相关服务出现异常，经工程师紧急修复，目前故障已恢复，非常抱歉对您造成的影响，若您有任何问题，请随时联系我们，感谢您的理解与支持！

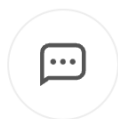
 腾讯云

2024-04-08

2018年十大云主机宕机事故：主流公有云全部落马

2019-01-07 17:30:14 来源: 易迈云计算

[举报](#)



0

2018年，云计算市场依然发展迅速，但是问题也没有间断，主流云厂商均未逃过宕机事件，更有甚者一年出现多次服务宕机，导致不少企业对公有云的信心受到了打击。易迈云总结了2018年国内外的十大云宕机事故，也希望所有云厂商能引以为戒。

1 数据存储与计算安全问题

数据存储

数据泄露风险

数据一致性风险

数据完整性风险

数据持久性风险

恶意用户风险

故障恢复风险

计算模型风险

多租户隔离风险

云SLA风险

用量超额风险

硬件平台风险

容灾备份风险

加密算法风险

加密凭据风险

暴力破解风险

解密失败风险

错误回收策略风险

额度不足风险

多租户隔离风险

云资源回收

数据显然是云计算的关键部分。将数据存储云端（特别是第三方云服务商的云端）显然在数据的存储与计算阶段引来了一系列新的隐患。

因此，我们需要能承受高频访问，高效访问，用量与成本易于估计可动态调整的，高度可信的数据存储与计算环境。云计算使用者也应该遵守安全最佳实践，充分利用云平台的安全特性保障自有云服务安全。

大规模公有云并不是绝对稳定的。前段时间的阿里云故障证明了这点。多地域多可用区混合云的策略被许多组织采纳。

2 虚拟化安全问题

虚拟机/容器镜像	加密存储性能开销风险	恶意代码注入镜像风险	镜像库可用性风险
虚拟机/容器管理	虚拟化蔓延风险	Hypervisor风险	虚拟机/容器逃逸风险
网络虚拟化	常规安全机制失效风险	传统安全设备失效风险	数据包嗅探与伪造风险
	动态网络配置风险	虚拟设备软件暴露风险	虚拟网络通信介质风险
虚拟机/容器迁移	虚拟机/容器克隆风险	虚拟机/容器移动风险	重放攻击风险
	多个版本配置文件风险	重放攻击风险	
虚拟机/容器平台	虚拟机超级跳跃风险	侧信道攻击风险	隐蔽信道攻击风险
	数据渗漏攻击风险	内存去重风险	恶意软件注入风险
	虚拟机/容器重置风险	虚拟机/容器回滚风险	

虚拟化技术是云计算的基础。虚拟化的层级在不同的服务模式（PaaS / IaaS）和技术路线（KVM，Bare Metal 等）下各有不同，但都是对计算资源与硬件资源的解耦。

虚拟化使得计算资源的灵活分配与分隔成为可能，然而这也正是虚拟化技术最大的安全问题来源。虚拟机/容器逃逸已成为常见攻击手段。

对于自建云的组织，应及时注意业内最新动态，及时修复漏洞。而对于使用第三方云的组织，则需要想办法加强其他方面的安全性和弥补措施，或者选用其他云服务。

2 虚拟化安全问题



滴滴出行

11-29 10:52 来自 微博网页版

再一次致歉

11月27日夜间发生的系统故障，给广大用户造成了诸多困扰和不便，在大家需要我们的时候，我们让大家失望了，再次向大家真诚致歉。

各项服务恢复的同时，我们在28日启动了内部复盘调查。初步确定，这起事故的起因是底层系统软件发生故障，并非网传的“遭受攻击”，后续我们将深入开展技术风险隐患排查和升级工作，全面保障服务稳定性，尽最大努力避免类似事故再发生。

目前，滴滴App的所有服务已经全部恢复。因这起事故给大家造成的困扰和问题，我们正在加快妥善解决。感谢大家对滴滴的鞭策、关心和包容。今天的滴滴还有很多不足，我们将以此为戒，在全公司范围内深刻反思，全力改正，继续努力做好服务保障。

滴滴出行

2023年11月29日 收起

415

1436

1.1万

运维的锅

网传滴滴故障真实原因

今天的事居然是因为机房的 k8s 升级升错了。。。

应该升级到 1.12 的 升级到 1.20 了
协议不兼容 kubelet 把整个永顺机房的 pod 都 kill 了

最致命的是控制节点也在那个机房
控制节点挂了 服务都没法重新部署 没法自己救自己了 太扯犊子了

头条 @辉哥传书vlog

3 网络安全问题

和虚拟化平台内部的网络的安全问题不同，此处讨论的是云计算，特别是公有云对公网暴露时存在的一系列安全问题。

作为目前信息世界的重要基础设施，云上服务的稳定性和安全性影响面极为广泛，必须重视。例如，许多云上服务都出现个人信息被盗取的事故。这些信息的泄露可能会催生电信诈骗等一系列犯罪事件。

此处列出的一些安全风险与云本身无关，但确实会影响到云上的服务。

恶意访问	钓鱼攻击风险	欺诈攻击风险
	爬虫风险	敏感信息窃取风险
网络协议	可监听协议的跨租户攻击风险	Cookie窃取/Session劫持风险
	中间人攻击风险	HTTP/HTTPS攻击风险
网络服务	API校验风险	元数据造假攻击风险
	SQL/XML注入风险	渗透攻击风险
可用性	负载均衡风险	DDOS攻击风险
	DNS解析风险	接口限流风险
移动平台	移动平台恶意软件风险	移动平台漏洞攻击风险
	越狱/Root/提权风险	移动平台云同步风险
特定场景安全	可观测性风险	日志相关风险

4 访问控制问题

无论上不上云，访问控制问题都始终是IT安全必须面对的话题。

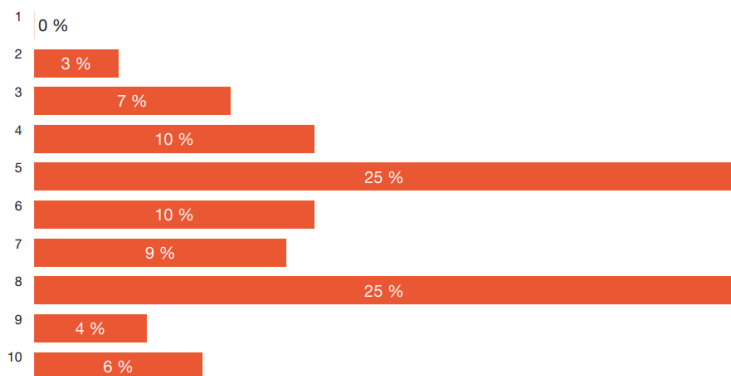
公有云面对的安全威胁比以往独立部署的服务更为广泛，如果公有云本身被攻击破坏，或是多租户间隔离被打破，带来的影响面会非常广泛。这需要使用者有更高的安全意识与更好的安全实践。

物理访问	恶意内部人员风险	恶意系统管理员风险
	冷启动攻击/硬件攻击	
用户凭据	鉴权服务风险	弱凭据风险
	钓鱼攻击/键盘记录/中间人风险	社会工程学攻击风险
实体认证	密码更新不及时风险	密码以外备选认证方式风险
	SAML暴露风险	活体认证攻击风险
鉴权	统一鉴权风险	恶意第三方应用风险
	错误权限分配风险	URL攻击风险
用户身份管理	身份与登陆状态同步风险	多身份协商风险
匿名化	攻击者匿名风险	反匿名攻击风险

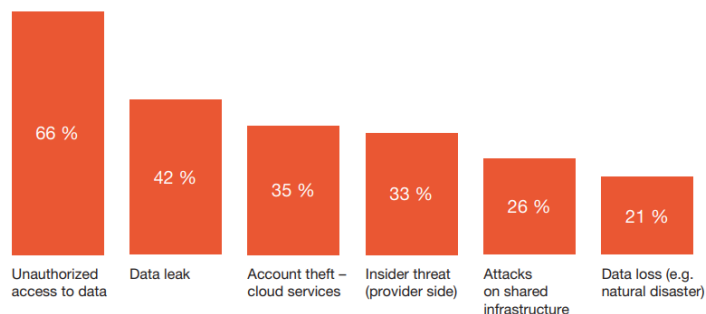
5 总结

云计算仍有广阔的发展与应用场景。我们不该因为云计算带来的安全隐患而全盘拒绝相关技术的推广与应用。目前，越来越多使用云的组织已高度关注云安全问题，但在云安全问题方面往往做得还不够。针对云安全问题，越来越多的组织开始选择基于云的安全解决方案。对于软件从业者而言，这既是机遇，也是挑战。

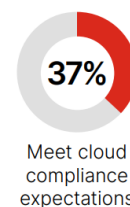
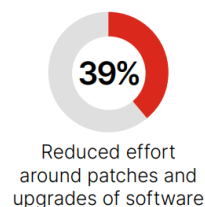
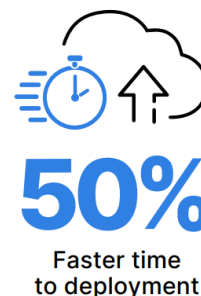
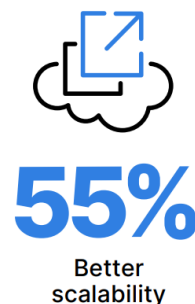
Do organisations consider the implemented cloud service security controls and measures to be sufficient?



What do organisations consider security threats relevant to cloud services?



What are the main drivers for considering cloud-based security solutions?



6 移动云安全白皮书-概述

本白皮书旨在通过介绍移动云在公有云领域的安全保障体系及产品服务能力，进一步增强客户将业务及数据向移动云平台迁移的信心，同时为客户选择安全的移动云产品，特别选择配套安全产品与服务等提供参考依据。白皮书主要内容包括：安全责任共担模型、安全合规与资质保障、安全运营管理、云平台安全防护、云产品自身安全、云安全产品与服务等。

移动云安全战略

合规：严格落实国家法律法规和行业监管要求，布局全行业的资质能力，打造“行业领先、国内权威、全球认可”的安全合规能力。

差异化：基于中国移动“网络、触达、央企、人才”的差异化优势，发挥央企责任担当，提供安全可靠服务，以运营商强大资源为基础，构建“云网融合”、“云数融合”、“云智融合”、“云边融合”，四融为一体的云服务能力。

高安全：建设一体化防御体系，实现“可管、可控、可信”安全目标，确保自己安全、伙伴安全、租户安全。



7 移动云安全白皮书-总体目标

安全合规资质

移动云满足国家、行业在安全合规监控、资质认证要求，并结合市场侧安全资质需求，对标友商安全资质情况，积极打造国内权威资质、全球通用资质、储备行业资质及海外资质所需能力，已获得了诸多“行业领先”、“国内权威”、“全球认可”的安全资质。

移动云安全资质规划

行业领先		国内权威		全球认可	
C5 (德国)	医疗	等保 2.0 三级 和等保 2.0 四级	云计算服务评估	ISO 27001 (信息安全管理体系)	ISO 27017 (云服务安全体系)
MTCS (新加坡)	mpaa (影视)	商用密码应用 安全性评估	数据安全治理认证	ISO 207701 (隐私管理体系)	ISO27018 (个人数据保护体系)
NESA (阿联酋)	SEC Rule- (证券)	数据安全治理 能力评估	政务云网信办审查	PCI-DSS (支付卡业务安全)	CSA-STAR (云安全管理体系)
GxP (医疗)	TISAX (汽车)	数据管理能力 成熟度评估	可信云认证	SOC 1/2/3/报告	ISO 22301 (业务连续性体系)

7 移动云安全白皮书-总体目标

安全防护技术体系

移动云高安全防护技术体系



7 移动云安全白皮书-总体目标

安全运营管理

移动云提出“一体化”安全运营管理理念，依靠运营流程制度、云原生平台技术能力、人员组织的协同演进，构建智能高效、可度量、可持续化自我优化升级的安全运营管理体系。



流程制度

- 资产、脆弱性管理
- 实时安全事件监控分析流程
- 实时安全事件响应恢复流程

组织架构

- 面向持续安全运营的人员架构体系
- 网络安全人才培养与供给

平台技术

- 研发安全平台
- 资产、漏洞平台
- 安全运营平台 (云安全大脑)

7 移动云安全白皮书-总体目标

安全产品服务

移动云为客户提供“全栈”式安全产品与服务，形成以“严选”为特色的安全产品服务能力，建立安全产品关键能力推进图谱，发挥“云网一体、云数融合”等优势，打造更具差异化优势的产品，全面构建“全栈”式安全产品。

在各个领域具备典型代表性产品，在产品安全与安全产品上具备良好的协同与演进机制。全面布局**15**款公有云产品、**2**款支撑系统，覆盖访问安全、边界安全、主机安全、应用安全、安全运营等领域。



8 移动云安全白皮书-安全架构

移动云安全架构可概括为“三横两纵”：三个横向维度分别是用户安全、云平台安全以及安全合规保障。两个纵向维度分别为安全管理和安全运营。

其中用户安全包括账户安全、基础安全、数据安全、业务安全、内容安全，全面覆盖了用户安全需求。

平台安全包括物理安全、虚拟化安全、平台数据安全、产品开发安全等防护能力，符合等保2.0等合规要求。

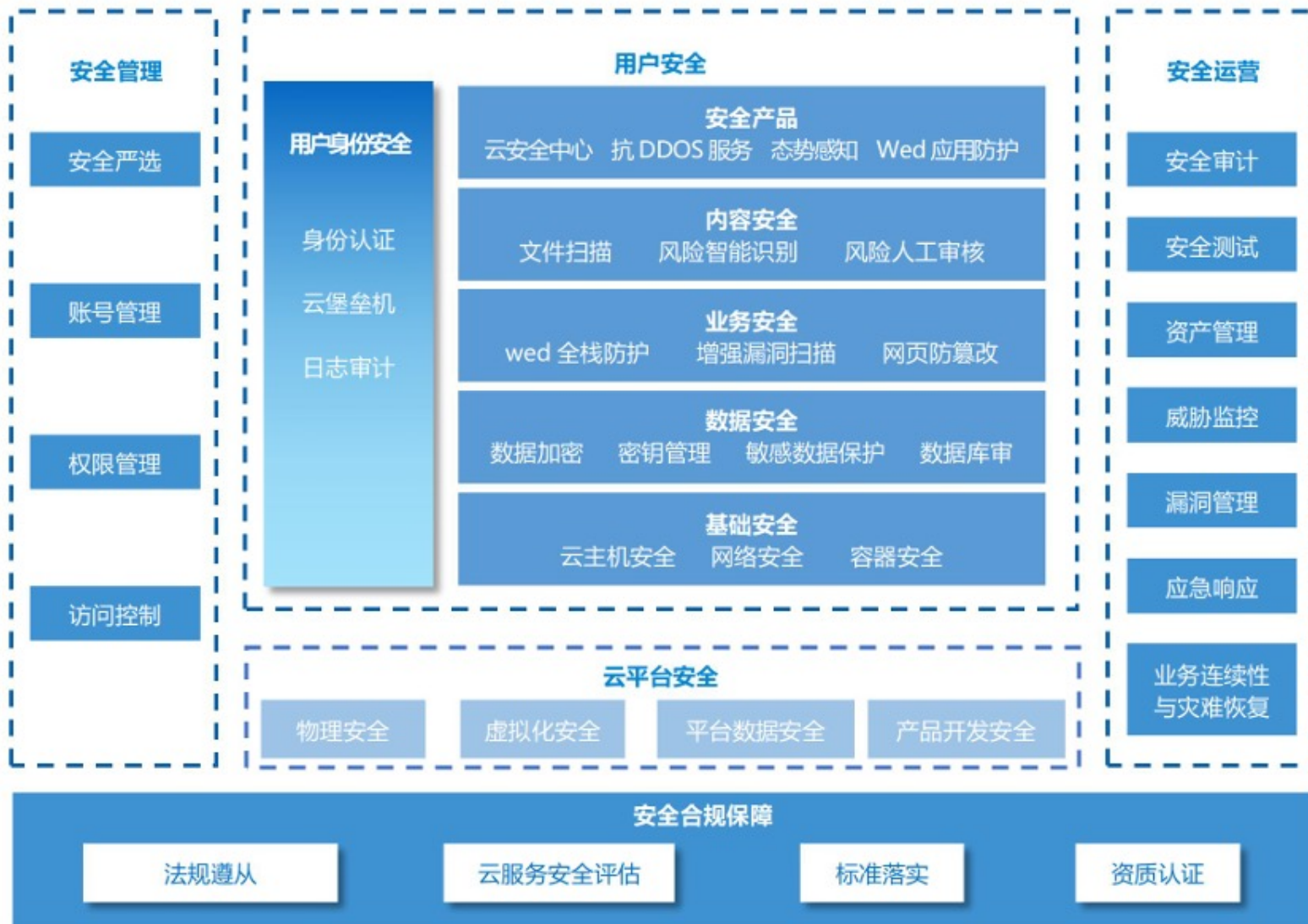
安全管理方面，遵循“责任匹配”和“最小授权”的要求开展运维工作。

安全运营依据事前预防、事中管控、事后处置的原则，构建全方位闭环管理机制，保障平台及用户安全。

安全合规保障方面，移动云全面符合国家和行业相关法规要求，拥有多项国内外安全资质。

8 移动云安全白皮书-安全架构

移动云安全架构



8 移动云安全白皮书-安全架构

移动云用户基础安全

移动云用户基础安全主要为云主机安全、网络安全、容器安全。

云主机安全：移动云提供主机类安全产品，可对用户云上资产进行集中化的安全防护，对安全威胁进行实时识别和响应。用户通过在云主机或服务器安装轻量Agent插件，即可获得漏洞检测、主机异常登录检测、暴力破解防护、基线合规检查、云平台配置检测等多种安全检测服务，全方位保护云上资产的安全并满足监管合规要求。

网络安全：基于SDN技术，使用户能够构建独立的网络空间，并通过网络ACL和安全组功能提高网络安全性。用户可以自定义网段和IP地址，也可以通过专线或VPN隧道将VPC与传统数据中心连接，灵活部署混合云。同时，可以配备云下一代防火墙、抗DDoS等安全产品实现网络边界安全防护。

容器安全：移动云提供针对容器集群的安全防护产品，应对容器全生命周期出现的安全风险，具备扫描镜像漏洞、检测容器逃逸、制定容器行为白名单等功能，有效阻止容器安全风险事件的发生

8 移动云安全白皮书-安全架构

移动云用户数据安全

移动云用户数据安全主要为数据加密、密钥管理、敏感数据保护、数据库审计。

数据加密：数据加密基于国家密码局认证的硬件密码机提供弹性、安全的云上数据加解密服务。用户能够使用多种加密算法保护云上业务数据安全，也能对密钥进行安全可靠的管理，满足安全合规要求。

密钥管理：提供安全、可靠、简单易用的密钥托管服务，帮助用户集中管理密钥，保护密钥安全。密钥管理服务通过使用硬件安全模块保护密钥的安全，所有的用户密钥都由硬件安全模块中的根密钥保护，避免密钥泄露。

敏感数据保护：移动云提供敏感数据保护产品，为企业客户提供敏感数据识别、静态脱敏、动态脱敏等数据安全能力，对敏感数据进行全方位保护。

数据库审计：移动云提供专业、主动、实时监控数据库安全的审计产品，可用于审计移动云平台中的云数据库、自建数据库，帮助企业对数据库操作行为进行审计，对安全威胁进行及时预警，提高数据安全等级和合规能力。

8 移动云安全白皮书-安全架构

移动云用户业务安全

移动云用户业务安全主要为Web全栈防护、增强漏洞扫描、网站安全卫士。

Web全栈防护：移动云为用户提供 Web应用安全防护，用户通过修改DNS解析记录将业务流量牵引至Web全栈防护集群实时检测防护，保障用户网站业务安全稳定。

增强漏洞扫描：移动云支持跨域资产扫描的系统漏洞扫描及Web应用漏洞扫描服务，并可生成更加丰富、全面的漏洞扫描报告。

网站安全卫士：移动云为用户的Web 站点目录提供全方位保护，通过对防护目录文件实时监控及时发现新增、修改、删除等非法操作，防止黑客、病毒等对网页进行非法篡改和破坏。

移动云用户内容安全

移动云用户内容安全主要为内容审核。

内容审核：移动云富媒体内容审核支持视频、音频、文档、图片、文本等内容审核，能精准识别多场景违法违规内容，高效防御内容风险

云安全中心：云安全中心提供统一的资产安全状况展示、实时安全威胁检测与响应功能。通过在主机安装Agent方式，为客户提供漏洞检测、异常登录、暴力破解、基线检查、云平台配置检测等多种安全检测能力，全方位保护云上资产安全并满足监管合规要求。

抗DDoS服务：移动云提供专业的针对DDoS（分布式拒绝服务）攻击防护的抗DDoS产品。抗DDoS产品通过内置的识别和检测分析技术检测DDoS攻击，通过流量清洗设备对DDoS攻击流量进行过滤，及时帮助用户发现网络中的各类DDoS攻击并实现对攻击流量的快速过滤，有效保护用户业务免遭攻击。

态势感知：移动云提供采用先进的大数据架构的态势感知产品。态势感知产品通过采集系统的网络安全数据信息，对所有安全数据进行统一处理分析，实现对网络攻击行为、安全威胁事件、日志、流量等网络安全问题的发现和告警，打造安全可监控、威胁可感知、事件可控制的安全能力。

Web应用防护：移动云提供基于对Web流量的解码和分析的Web应用防护产品。Web应用防护产品支持解析多种常见HTTP协议数据提交格式，可应对Web应用中的各类攻击，防御OWASP常见威胁，如SQL注入、XSS注入、跨站请求伪造攻击、Cookie篡改以及应用层Web攻击等，能有效解决网页挂马、敏感信息泄露等安全问题。

8 移动云安全白皮书-安全架构

移动云用户身份安全

移动云用户身份安全主要为身份认证、云堡垒机、日志审计。

移动云提供完善的身份验证、注册信息审核、用户真实身份鉴别机制，在规定时间内未进行实名认证的客户不能在移动云上订购和管理相关资源。

身份认证

移动云帮助客户更加精细地管理云上资产，实现对云上资产运维过程的事前规划、事中控制和事后审计，建立安全、高效、可控的运维管理机制。

云堡垒机

移动云针对大量分散的异构日志进行集中采集、统一管理、存储、统计分析，可协助企业满足等保合规要求、高效统一管理资产日志并为安全事件的事后取证提供依据。

日志审计

物理安全：移动云机房从场地、设备、介质安全等方面保障平台物理安全。

虚拟化安全：移动云通过计算、存储、网络虚拟化来保障云计算环境下的多云服务客户隔离，能够保证每个虚拟机能获得相对独立的物理资源，并能屏蔽虚拟资源故障，确保某个虚拟机崩溃后不影响虚拟机监控器及其他虚拟机。

平台数据安全：移动云平台从数据产生、数据传输、数据存储、数据使用、数据迁移、数据销毁、备份和恢复全生命周期保障数据安全。敏感信息加密存储、传输过程中使用加密传输协议同时具备权限分配和身份认证能力。

产品开发安全：

（1）**产品安全设计：**移动云产品主要从接入安全、安全防护、业务安全、日志安全、数据安全等方面进行安全设计。

（2）**安全编码：**移动云已统一产品开发过程中涉及的安全要求，确保各产品编码过程中使用同一套代码开发安全规范。

（3）**安全测试：**所有云产品发布前都经过了多轮安全测试，测试用例覆盖了安全设计阶段的安全需求以及攻击者视角的渗透测试用例，并加入了客户安全需求和业界标准。

（4）**安全发布：**移动云产品安全发布通过建立多部门集中评审的方式，实现产品发布安全可控。

8 移动云安全白皮书-安全架构

移动云安全管理

移动云安全管理主要为账号管理、权限管理、访问控制。

账号管理：移动云内部账号分为正式员工账号和外部合作伙伴两种账号，两种号区分申请流程，统一使用内部技术服务支撑系统进行账号生命周期管理，使用双因子因素进行身份认证，并定期对账号进行审计。

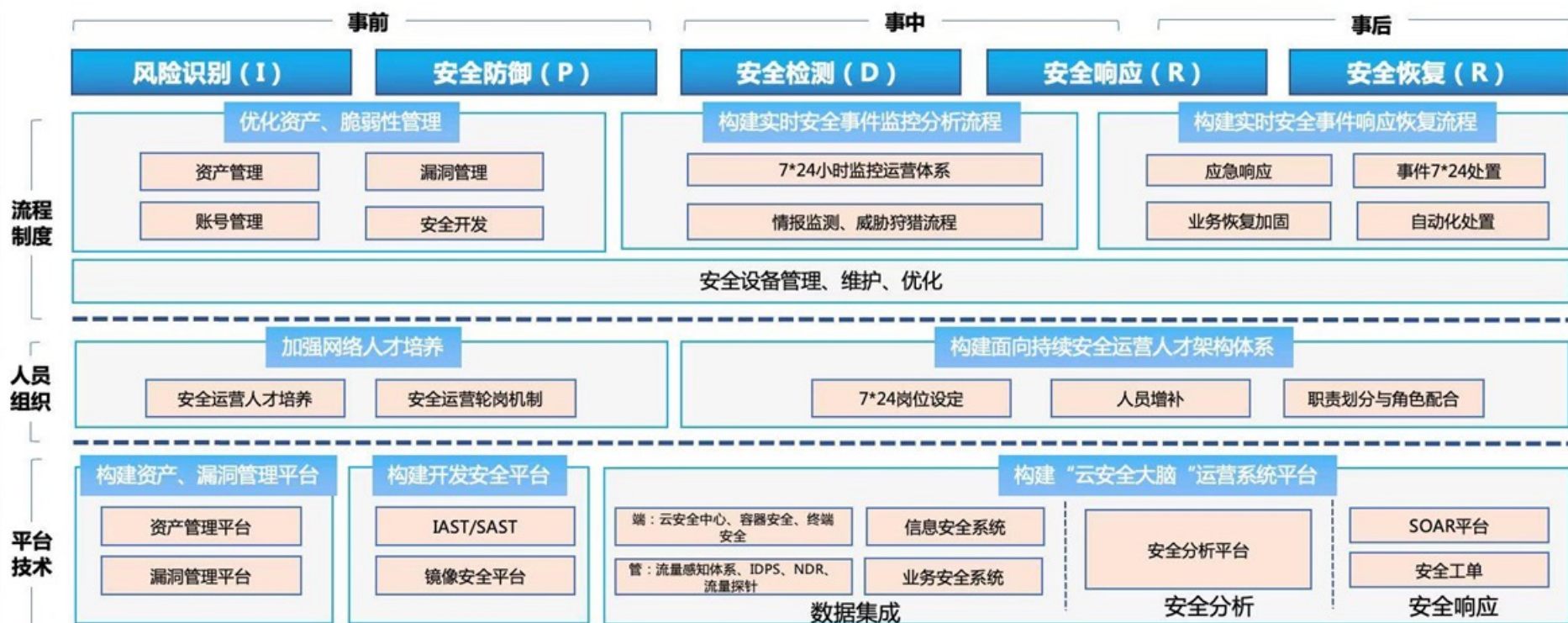
权限管理：移动云账号权限管理遵循“责任匹配”和“最小授权”原则进行管理，授予人员有限的资源访问权限。

访问控制：内部通过权限申请工单，申请必要的堡垒机访问权限，由资源负责人进行审批后，自动化开通和回收堡垒机权限。对于重要的生产系统，设置金库指令，人员根据需要申请金库指令执行，资源负责人进行实时审批授权，从而保障重要生产系统的数据安全。

8 移动云安全白皮书-安全架构

移动云安全运营

移动云“一体化”安全运营架构围绕“流程制度”、“人员组织”、“平台技术”构建。整体贯穿事前、事中、事后各阶段，从“风险识别（I）”、“安全防御（P）”、“安全检测（D）”、“安全响应（R）”、和“安全恢复（R）”五个方面，全面覆盖安全运营全周期。

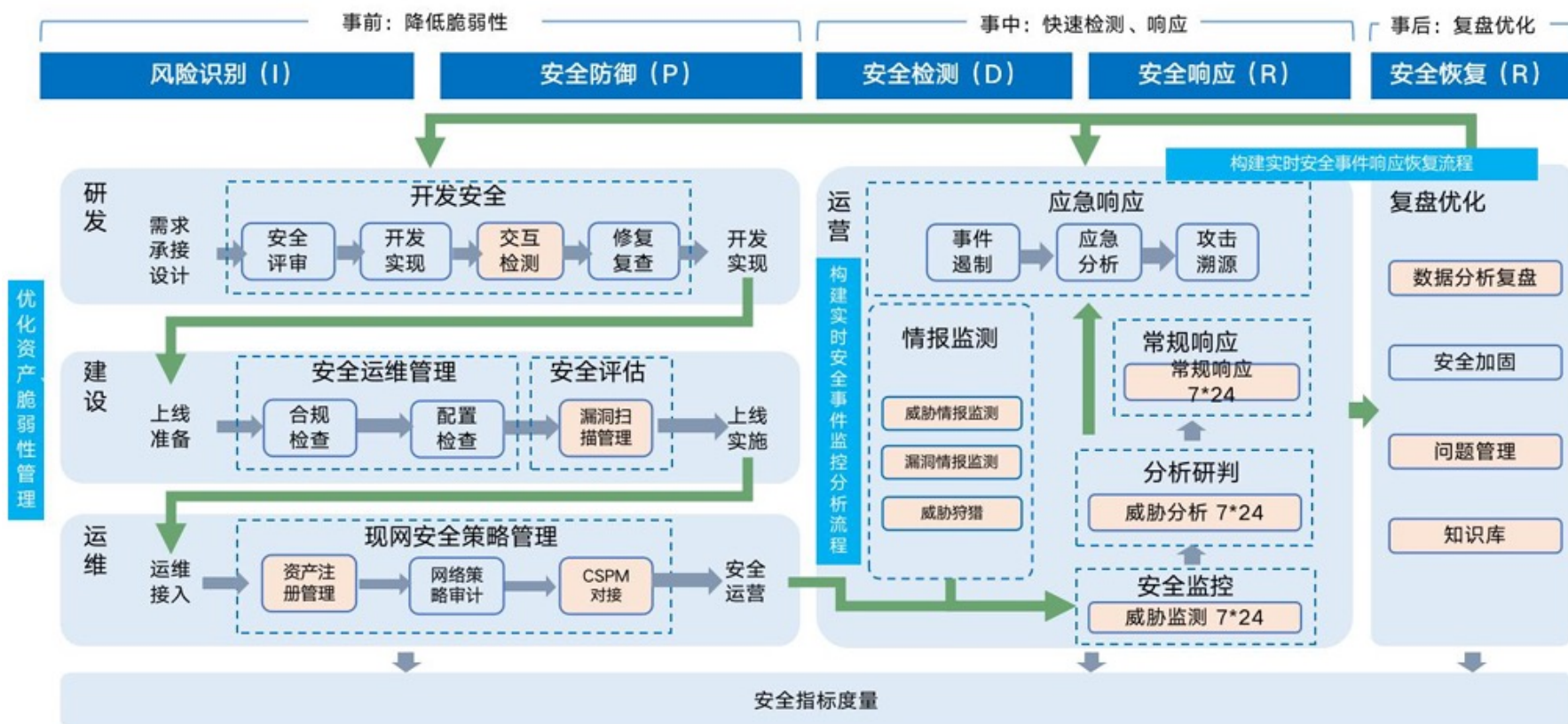


安全运营体系架构

8 移动云安全白皮书-安全架构

移动云安全运营-流程制度

移动云安全运营流程制度围绕“事前降低脆弱性风险”，“事中构建快速监测与响应能力”，“事后复盘、沉淀经验、迭代优化”的思路构建。



移动云安全运营-流程制度

开发安全流程嵌入到移动云所有产品研发工作中，从需求设计到开发实现，将通过安全评审、交互检测，只有通过脆弱性修复，满足安全研发标准的产品才能进入后续上线环节。

在**产品建设期**，将开展合规检查、配置检查以及上线前的漏洞扫描管理，之后产品上线实施，进入运维期。

在产品上线投入**运维**时，将会在资产平台注册。同时，网络策略的开通都将被审计。云资产还会受到安全态势管理（CSPM），不合规的，或风险度较高的资产将会被及时识别。

在**事中运营阶段**，安全流程主要围绕构建快速的监测与响应能力。通过7*24小时的安全监测、安全分析研判、安全常规响应、安全应急响应构建实时的被动安全监测分析与响应能力。同时，通过情报监测、威胁狩猎等流程，将安全调整为主动姿态，以“主动安全”的姿态应对当前复杂多变的网络安全威胁。

在**事后阶段**，移动云将通过定期复盘以及特殊安全事件复盘的形式，沉淀安全运营经验知识形成知识文档，查漏补缺进行安全体系优化，进一步提升安全水平。

8 移动云安全白皮书-安全架构

移动云安全运营-技术平台

移动云安全运营深入构建“事中、事后”平台技术体系，围绕安全事件监测、分析、响应，嵌入NDR、EDR、SIEM、SOAR等相关技术，构建了基于“**数据集成、安全分析、结果响应**”核心流程线条的安全运营技术平台体系。

数据集成部分：紧抓“端”、“管”安全数据，兼顾信息与业务安全数据以及其他安全日志。依托数据仓库及数据湖技术，构建安全大数据层。

安全分析部分：围绕“被动+主动”的安全监测分析流程，构建基于SIEM技术的实时关联分析系统与基于AI、统计、威胁狩猎等长时分析手段的离线分析系统。检测到的安全告警以及分析出的安全事件都将传递到响应环节。与此同时，3.5 移动云安全合规保障 移动云还引入自动化评估技术，对安全监测的可靠性进行自动化评价。

安全响应部分：依靠SOAR工具对绝大多数常规安全事件进行实时响应。对于复杂的安全事件，或新种类的安全事件，将由人工进行处置，并总结经验，固化处置流程，供后续自动化处置流程的升级进行参照。

8 移动云安全白皮书-安全架构

移动云安全合规保障

移动云安全合规保障主要为保障安全合规、资质认证。

移动云积极参与国家云安全相关标准规范的制定，对照国家法律法规要求，持续开展安全合规工作。先后通过了国家网信办云计算服务安全评估、公安部等级保护2.0三级测评，同时积极对照《网络安全法》、《数据安全法》等一系列网络安全法规及标准，确保移动云始终满足各类监管要求，为客户提供安全可信的云服务。

移动云先后通过了ISO27001信息安全管理体系、ISO27017云服务安全管理体系、ISO27018云隐私保护体系、ISO22301业务连续性管理体系、CSASTAR云安全评估认证等一系列网络安全资质认证，证明移动云信息安全管理体系及网络安全防护水平得到认可。

9 移动云安全白皮书-网络安全责任

移动云公有云服务网络安全责任共担模型

云计算环境的安全性主要依赖于云服务商所采取的安全保障措施和提供的安全保护功能。移动云作为向云服务客户提供服务的实体，负责保护运行所有移动云服务的基础设施，该基础设施由运行移动云服务的硬件、软件、网络和设备组成。

移动云负责运营基础设施层和平台安全，而云服务客户通过终端节点访问、存储和检索云上数据，负责管理其数据（包括加密选项），对其资产进行分类，以及分配适当的权限。云服务客户责任由其所选的移动云服务协议确定，云服务客户在履行安全责任时必须完成对应的安全配置工作。

例如，云主机等服务被归类为基础设施即服务，要求云服务客户执行所有必要安全配置和管理任务。部署云主机实例的云服务客户需要负责操作系统（包括更新和安全补丁）的管理，以及对在实例上安装的任何应用程序软件或实用工具进行管理，并对每个实例通过移动云提供的防火墙（称为安全组）进行安全配置。

云计算服务的安全性和合规性需要云服务商（CSP）与云服务客户共同分担。“云安全责任共担”已经成为业界共识。

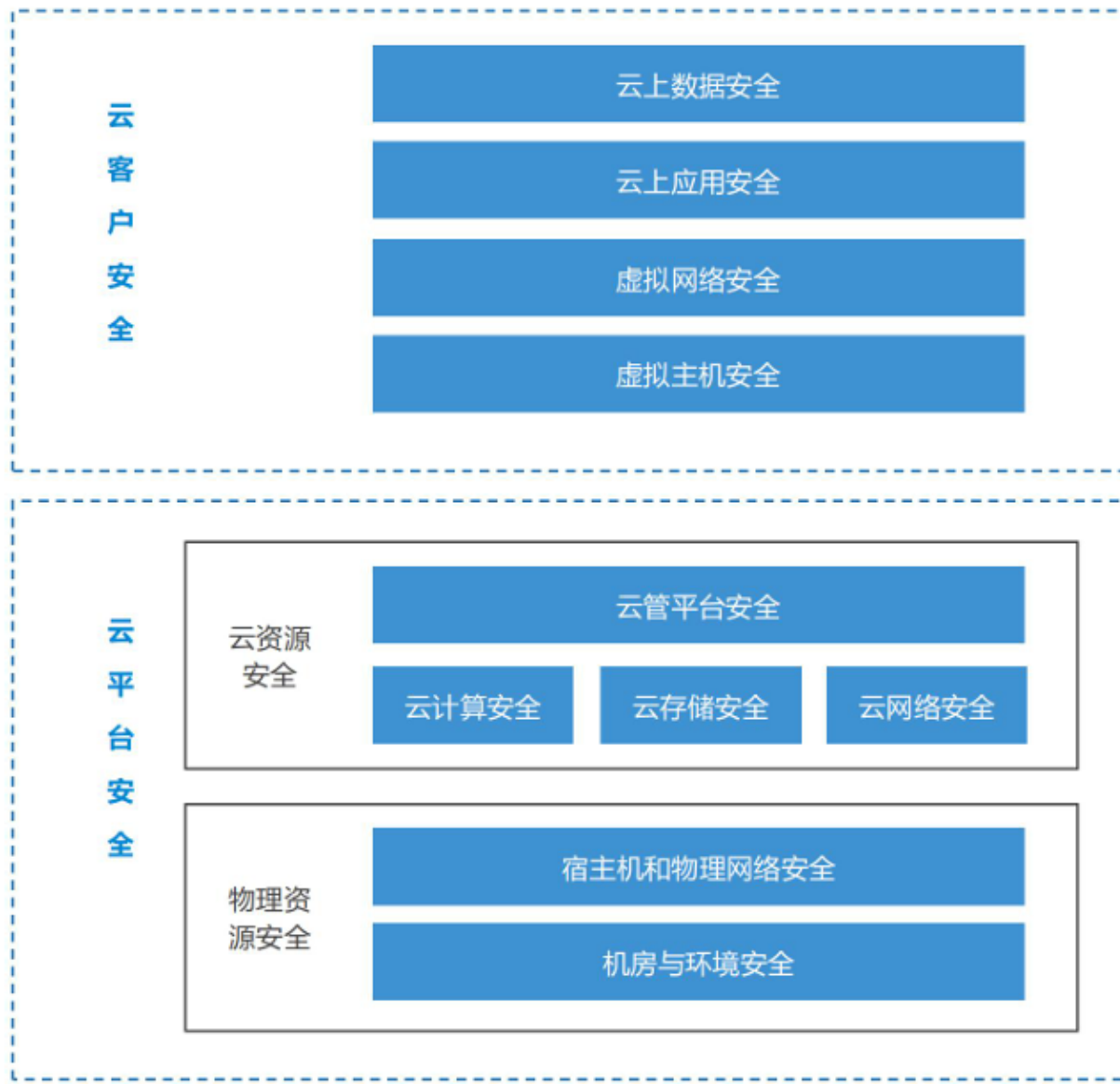
9 移动云安全白皮书-网络安全责任

云服务商与云主管部门共同责任



9 移动云安全白皮书-网络安全责任

云服务商与云服务客户责任划分边界



9 移动云安全白皮书-网络安全责任

云服务商与云服务客户责任划分边界说明

单 位	责任边界	说明
云服务商	设施层安全； 负责硬件层、资源抽象层、虚拟化技术资源层的安全。	包括机房采暖、通风、空调、电力和通信等机房基础设施的安全保障。 云服务商自身云平台组成的服务器、网络设备和安全设备等硬件层安全，及其云管理平台安全； 政务云平台网络边界的安全防护。
云服务客户	负责自身部署系统的软件平台层、应用软件层安全和系统数据安全，实施对这些资源操作、更新、配置的安全可靠管理。	业务系统相关的安全责任，包括主机、应用和数据安全，如操作系统、数据库、中间件和应用系统的安全配置检查和加固，应用系统的升级维护和日常代码审计、渗透测试等，以及业务数据的加密和备份等。

9 移动云安全白皮书-网络安全责任

IaaS云服务商与云服务客户的责任划分

层面	安全要求	安全组件	责任主体
物理和环境安全	物理位置选择	数据中心及物理设施	云服务商
网络和通信安全	网络结构、访问控制、远程访问、入侵防范、安全审计	物理网络及附属设备、虚拟网络管理平台	云服务商
		云客户虚拟网络安全域	云服务客户
设备和计算安全	身份鉴别、访问控制、安全审计、入侵防范、恶意代码防范、资源控制、镜像和快照保护	物理网络及附属设备、虚拟网络管理平台、物理宿主机及附属设备、虚拟机管理平台、镜像等	云服务商
		云客户虚拟网络设备、虚拟安全设备、虚拟机等	云服务客户
应用和数据安全	安全审计、资源控制、接口安全、数据完整性、数据保密性、数据备份恢复	云管理平台（含运维和运营）、镜像、快照等	云服务商
		云客户应用系统及相关软件组件、云客户应用系统配置、云客户业务相关数据等	云服务客户
安全管理机构和人员	授权和审批	授权和审批流程、文档等	云服务商
系统安全建设管理	安全方案设计、测试验收、云服务商选择、供应链管理	云计算平台接口、安全措施、供应链管理流程、安全事件和重要变更信息	云服务商
		云服务商选择及管理流程	云服务客户
系统安全运维管理	监控和审计管理	监控和审计管理的相关流程、策略和数据	云服务商、云服务客户

9 移动云安全白皮书-网络安全责任

PaaS云服务商与云服务客户的责任划分

层 面	安全要求	安全组件	责任主体
物理和环境安全	物理位置选择	数据中心及物理设施	云服务商
网络和通信安全	网络结构、访问控制、 远程访问、入侵防范、 安全审计	物理网络及附属设备、虚拟网络管理平台、虚拟网络安全域	云服务商
设备和计算安全	身份鉴别、访问控制、 安全审计、入侵防范、 恶意代码防范、资源控制、 镜像和快照保护	物理网络及附属设备、虚拟网络管理平台、物理宿主机及附属设备、虚拟机管理平台、镜像、虚拟机、虚拟网络设备、虚拟安全设备等	云服务商
应用和数据安全	安全审计、资源控制、 接口安全、数据完整性、 数据保密性、数据备份恢复	云管理平台（含运维和运营）、镜像、快照等	云服务商
		云客户应用系统及相关软件组件、云客户应用系统配置、云客户业务相关数据等	云服务客户
安全管理机构和人员	授权和审批	授权和审批流程、文档等	云服务商
系统安全建设管理	安全方案设计、测试验收、 云服务商选择、供应链管理	云计算平台接口、安全措施、供应链管理流程、安全事件和重要变更信息	云服务商
		云服务商选择及管理流程	云服务客户
系统安全运维管理	监控和审计管理	监控和审计管理的相关流程、策略和数据	云服务商

9 移动云安全白皮书-网络安全责任

SaaS云服务商与云服务客户的责任划分

层面	安全要求	安全组件	责任主体
物理和环境安全	物理位置选择	数据中心及物理设施	云服务商
网络和通信安全	网络结构、访问控制、远程访问、入侵防范、安全审计	物理网络及附属设备、虚拟网络管理平台、虚拟网络安全域	云服务商
设备和计算安全	身份鉴别、访问控制、安全审计、入侵防范、恶意代码防范、资源控制、镜像和快照保护	物理网络及附属设备、虚拟网络管理平台、物理宿主机及附属设备、虚拟机管理平台、镜像、虚拟机、虚拟网络设备、虚拟安全设备等	云服务商
应用和数据安全	安全审计、资源控制、接口安全、数据完整性、数据保密性、数据备份恢复	云管理平台（含运维和运营）、镜像、快照等、应用系统及相关软件组件	云服务商
		云客户应用系统配置、云客户业务相关数据等	云服务客户
安全管理机构和人员	授权和审批	授权和审批流程、文档等	云服务商
系统安全建设管理	安全方案设计、测试验收、云服务商选择、供应链管理	云计算平台接口、安全措施、供应链管理流程、安全事件和重要变更信息	云服务商
		云服务商选择及管理流程	云服务客户
系统安全运维管理	监控和审计管理	监控和审计管理的相关流程、策略和数据	云服务商

云服务商安全责任

移动云提供云服务，在确保云平台安全控制措施的有效性、重大变更风险的可控性、应急响应的时效性的同时，根据不同的服务模式，担负相应的安全责任。

IaaS服务模式：保障物理资源、网络资源、存储计算、Hypervisor、虚拟化网络等虚拟化组件及底层资源的安全性，为云服务客户提供安全的硬件基础设施和设备。

PaaS服务模式：保障虚拟化组件及底4.3云服务客户安全责任层资源以及操作系统、中间件、Runtime等软件平台的安全性，为云服务客户提供各类安全服务。

SaaS服务模式：保障虚拟化组件及底层资源、软件平台以及应用程序的安全性，为云服务客户提供数据加密等数据安全保护功能。

云服务客户安全责任

云服务客户是为使用移动云资源同中国移动建立业务关系的参与方。云服务客户可以直接作为云服务客户使用移动云提供的云服务，也可以作为云代理商，为保证云服务客户使用云服务的运行稳定而提供服务计量、计费与资源购买等运行管理服务。云服务客户作为移动云的使用者，也需要根据不同的云服务模式，担负相应的安全责任。

IaaS服务模式：云服务客户负责自行部署的操作系统、网络环境运行环境和应用的安全。

PaaS服务模式：云服务客户负责自行开发和部署的应用及其运行环境的安全。

SaaS服务模式：云服务客户负责数据生成、传输、存储及使用等环节的数据安全。

10 移动云安全白皮书-安全合规保障

保障安全合规

移动云积极参与国家云安全相关标准规范的制定，对照国家法律法规要求，持续开展安全合规工作。先后通过了国家网信办云计算服务安全评估办法、公安部网络安全等级保护2.0三级测评，同时积极对照国务院颁布的《关键信息基础设施安全保护条例》等一系列网络安全法规及标准，确保移动云始终满足各类监管要求，为客户提供安全可信的云服务。

安全资质认证

移动云遵从国家和行业的合规性要求，全力打造值得用户信赖的云服务，建设和运行安全可靠的云生态环境。截至目前，移动云先后通过了多家权威机构的认证。

10 移动云安全白皮书-安全合规保障

资 质		简 介
国际认 证资质	ISO 27001 信息安全管理体系	ISO 27001 信息安全管理体系国际认证是被广泛采用的全球安全标准, 移动云作为通过此项认证的云计算服务提供商, 从数据安全、网络安全、通信安全、操作安全等各个方面证明移动云平台履行的安全职责。
	ISO 27017 云服务安全 管理体系	ISO 27017 提供了一套使用云服务的相关信息安全控制指引, 包含与 ISO/IEC 27002 相关控制的额外实施指引, 以及与云服务特性相关的额外控制以及相应实施指引。
	ISO 27018 云隐私保护体系	ISO 27018 是针对云服务商对云上个人数据的安全防护的国际标准认证, 为云上个人身份信息处理者提供一套守则, 以保护公共云中的个人身份信息 (PII) 不受侵犯, 是目前国际上最权威、最严格、也是最被广泛接受和应用的信息安全体系认证。
	ISO 22301 业务连续性管理体系	ISO 22301 业务连续性管理体系, 能够帮助企业制定一套一体化的管理流程计划, 使企业对潜在的灾难加以辨别分析, 帮助其确定可能发生的冲击对企业运作造成的威胁, 并提供一个有效的管理机制来阻止或抵消这些威胁, 减少灾难事件给企业带来损失。
	CSA STAR 云安全评估认证	CSA STAR 由英国标准协会 (BSI) 和国际云安全权威组织云安全联盟 (CSA) 联合推出。

10 移动云安全白皮书-安全合规保障

国内 资质	公安部 网络安全 等级保护 2.0	移动云通过了公安部网络安全等级保护 2.0 三级测评。
	工信部云计算服务能力 评估 ITSS	移动云通过了工信部云计算服务能力评估二级的测评，证明了移动云的服务能力满足了相应的服务标准。
	可信云 云计算服务认证	移动云主机、对象存储、云数据库、块存储、负载均衡等多款产品和服务获得了可信云服务认证，体现了移动云的安全可靠。
	云计算服务安全评估	移动云基础架构通过国家互联网信息办公室、国家发展和改革委员会、工业和信息化部、财政部的云计算服务安全评估，证明了移动云的服务能力满足了相应的服务标准。

11 移动云安全白皮书-安全运营管理

移动云安全管理

账号管理

移动云内部账号使用双因子因素进行身份认证，强制员工对账号设置复杂密码并定期修改密码，不能进行账号共享，定期对账号进行审计。云平台用户密码加密存储。涉及密码信息的使用加密传输。代码中连接数据库等中间件的密码，均加密存储。自服务门户提供统一的认证管理，支持基于CAS的单点登录服务实现自服务门户的认证和满足第三方页面集成的需求，同时对第三方的接口提供。同时，移动云支持AccessKey（AK）方式认证，AK是云服务客户调用云服务API的身份凭证，用于在云服务客户通过API访问移动云资源时对云服务客户身份进行认证。

权限管理

移动云账号权限管理遵循“责任匹配”和“最小授权”原则开展，授予员工有限的资源访问权限。员工需要通过权限申请工单流程，申请必要的堡垒机访问权限，由资源负责人进行审批后，自动化开通和回收堡垒机权限。对于重要的生产系统，设置金库指令，员工根据需要申请金库指令执行，资源负责人进行实时审批授权，保障重要生产系统的数据安全，同时可对员工的访问操作进行安全审计。

访问控制

员工需要通过权限申请工单流程，申请必要的堡垒机访问权限，由资源负责人进行审批后，自动化开通和回收堡垒机权限。对于重要的生产系统，设置金库指令，员工根据需要申请金库指令执行，资源负责人进行实时审批授权，保障重要生产系统的数据安全。

11 移动云安全白皮书-安全运营管理

移动云安全运营

移动云安全运营遵从IPDRR模型，即从“风险识别（I）”、“安全防御（P）”、“安全监测（D）”、“安全响应（R）”、和“安全恢复（R）”五个方面，全面覆盖安全运营全周期。事前阶段，从做好风险识别（I）与安全防御（P）类工作，做到事前预防。事中阶段，做好安全监测（D）与安全响应（R），管控事态。事后阶段，做好安全恢复（R），积极复盘优化。



移动云安全运营

事前风险识别与安全防御

资产管理：对暴露面及内网的资产安全管理，通过多种手段对移动云全量资产进行安全管理，通过采集资产端口、服务、框架、组件等信息，实现资产动态安全管控。所有资产上线均需经过流程审批，做好定级备案，对未经备案的资产上线行为进行监控、通报、处置。完善的资产信息为新增高危漏洞排查提供快速定位。

漏洞管理：分为研发阶段的漏洞压降与系统建设与运维阶段的漏洞管理。

针对研发阶段工作，引入软件安全开发生命周期管理，收敛软件漏洞。通过安全意识管理，安全设计评审，规范安全编码，管控第三方组件安全及安全测试，提升漏洞收敛率。

针对系统建设及运维阶段，遵守业务上线安全指引，收敛上线系统脆弱性指标，对第三方合作的产品、外采的产品或依赖的开源组件，进行供应链安全管控。与此同时，对内外部发现的移动云安全漏洞做好闭环管理。主机安全层面，持续优化漏洞自动化巡检机制，压降误报率和漏洞率。应用安全层面，在产品研发生命周期开展必要的安全测试，防止安全风险流入现网，同时及时修复外部发现的漏洞，确保平台安全。

移动云安全运营

事中安全监测与安全响应

安全监测：移动云配备了完善的安全监测与防御系统，安全大数据分析平台。日常威胁监控工作包括对网络侧的系统漏洞攻击、应用漏洞攻击、流量攻击进行监控分析处置，对安全检测规则进行分析优化，持续压降误报率和漏报率。对主机侧发生的恶意代码、威胁诱捕告警结合威胁情报进行分析溯源，对内部异常行为进行审计和追溯，对外部发布的漏洞情报进行跟踪并及时排查修复。

安全响应：主要针对实际发生的安全事件，包括但不限于攻击事件、漏洞事件、违规事件、数据泄露事件、恶意代码感染事件等，能够按照预案有序处置，将影响降到最低。对于常规性安全事件，将利用安全编排与响应的自动化系统进行自动化处置，并持续优化响应剧本，将处置时长降低。对新发生事件，由人工24*7投入分析，并对新发现问题进行评估，落实闭环整改与优化。

移动云安全运营

事后安全恢复

移动云架构和产品设计符合业务连续性和灾难恢复的要求，日常运维工作对业务连续性进行持续监控，网络侧对业务的端口、服务、业务进行拨测和告警，主机侧对资源使用情况、进程状态进行信息采集和告警。

告警设置两道阈值，第一道阈值对潜在的业务宕机隐患进行预警，对相关对象或资源进行调度，第二道阈值为故障红线，对主要故障隐患进行强制措施。当发生故障时按照应急预案及时采取疏散措施，将业务影响降到最低。同时，针对安全运营做好定期复盘，或随重大事件复盘。及时总结经验，优化安全技术手段与运营流程，持续提升运营工作质量。

移动云产品开发安全管理

云产品安全设计

安全防护：合理规划网络服务端口的开放，只开放实现业务功能所必须的网络服务端口。

业务安全：对云服务客户登录、业务使用等过程中的高风险环节合理规划风险管控手段；合理规划输入验证功能，对所有来源的输入进行验证；

日志安全：合理规划产品的设备日志及业务日志的存储方式；合理规划日志记录和日志审计功能。

数据安全：合理规划数据产生、传输、存储、销毁阶段的安全管理和技术保障方式。

云产品安全编码

移动云严格遵从内部发布的安全编码规范，开发和测试人员在上岗前均通过了对应规范的学习和考试，同时引入了静态代码扫描工具每日检查，其结果数据进入持续集成和持续部署工具链，通过质量门限进行控制，以评估云产品的质量。所有云产品在发布前，均需完成静态代码扫描的告警清零，有效降低上线时编码相关的安全问题。

移动云产品开发安全管理

云产品安全测试

所有云产品发布前都经过了多轮安全测试，包括但不限于内部测试阶段的认证、鉴权、会话安全等微服务级功能和接口安全测试，验收测试阶段通过对API和协议的fuzzing测试验证服务集成，终极测试阶段的数据库安全等安全专项测试。测试用例覆盖了安全设计阶段的安全需求以及攻击者视角的渗透测试用例，并加入了客户安全需求和业界标准。

云产品安全发布

研发及测试工作完成后，通过产品管理系统发起产品发布工单，对照相关制度由各部门进行会签评审，若不符合相关安全要求则驳回整改，整改情况通过测试后，由产品部再度提交产品管理系统进行二次评审，直至评审通过后才可发布。

产品安全发布需满足两个条件，一是产品需求说明书中需明确产品安全需求，并在后续产品设计及开发过程中完成产品安全需求落地；二是产品静态代码扫描中高危漏洞整改完成方可发布。

12 移动云安全白皮书-平台安全防护

物理安全

在基础设施与物理环境方面，移动云各节点机房所处物理环境均具有防震、防风 and 防雨的能力，且不处于建筑物的顶层或地下室；人员进入机房需提前申请，机房出入口配备了单向电子门禁系统；机房内同时设置视频监控系统，专人值守且巡检；机房内部署火灾自动消防系统、水敏感检测元件、抗静电地板、精密空调等相关设施对机房的防火、防水、防潮、防静电和温湿度等方面进行防护和控制。

虚拟化安全-镜像安全

镜像是移动云主机运行的模板，一般包括操作系统和预装的软件。移动云网站所提供的公共镜像默认会做基础的安全加固，保证实例在启动的第一时间就能得到基本的安全保护，为云服务客户提供更可靠的安全保障。同时，移动云推出的大云企业操作系统（BC-Linux）集成了安全加固工具，可以为大云企业操作系统提供深度安全扫描、安全检测、系统加固和漏洞监测等功能，同时还支持一键加固、动态调整安全加固参数、一键还原等功能。

虚拟化安全-虚拟化安全技术

CPU隔离

CPU需要保障资源的访问有明显的边界，不会以未经授权的方式访问其他云服务客户的资源，所以CPU隔离主要体现两个方面：虚拟机和物理机之间的隔离，以及虚拟机和虚拟机之间的隔离。基于硬件辅助虚拟化技术，使得CPU拥有ROOT和NON-ROOT两种操作模式，并且两种模式正交，Hypervisor和虚拟机运行在不同模式，可以有效避免虚拟机部分指令越权访问物理机资源的可能。此外VMCS结构和VCPU一一对应可以避免虚拟机访问到其他虚拟机的资源，有效保障不同虚拟机CPU之间的资源隔离。

安全加固

一方面移动云虚拟化平台通过裁剪虚拟化组件中与云上设备无关的代码来降低可能的受攻击面（attacksurface），提升虚拟化组件安全性，另一方面，虚拟化组件也必须运行在授信的执行环境上才能保障每个可执行的二进制文件在执行时不会被替换或者篡改，因此，移动云对宿主机OS都进行了安全加固，保证了底层执行环境的安全可信，实现了从底层OS到虚拟化组件整个链路的安全保障。

12 移动云安全白皮书-平台安全防护

虚拟化安全-虚拟化安全技术 内存隔离

基于硬件辅助的内存虚拟化技术，直接在硬件层面完成客户机虚拟地址->客户机物理地址->宿主机物理地址两次地址转换，确保不同虚拟机的地址映射在不同的地址区间，从而保证虚拟机不会访问到其他云服务客户的内存数据，并且实例释放后，TLB中的数据也会被VMM重刷释放，保障云服务客户数据的安全。

存储隔离

虚拟化层的陷入陷出模型决定了IO的虚拟化设计注定是设备驱动分离的架构，所有的IO操作都属于敏感指令，会触发VM-Exit，即虚拟机的所有IO请求都会被Hypervisor截获处理，虚拟机的IO操作只能下发给分配给它的物理磁盘，保证了虚拟机磁盘的安全隔离。

网络隔离

云服务客户侧容器通常运行在云服务客户VPC的云主机上，提供了VPC级别的网络隔离、虚拟机级别的隔离。在同一个云主机上，提供基于Linuxcgroup、namespace的安全隔离。云服务客户的持久化数据建议保存到云存储上。对于应用临时产生的数据，可使用K8s emptydir保存，将在容器销毁时删除数据。

数据资产识别

移动云建立数据资产管理能力，具备主动或被动资产数据扫描发现技术，可摸清现网数据资产状况。在全面识别发现数据资产后，对数据进行敏感资产识别，理清敏感数据分布情况，实现敏感资产常态化管理。利用分类分级技术细化资产类别，对数据资产进行属性类别分级，形成分类分级清单，以便对不同类别数据开展不同的管控，加强敏感数据差异化管控能力。

数据脱敏

移动云平台在生产运营过程中收集和产生大量的敏感信息数据，内部业务人员在日常业务处理或办理过程中可能接触敏感数据。为了保护数据隐私安全，移动云强化数据安全基础防护能力，建设数据安全管理平台具备敏感数据识别和脱敏能力。移动云基于不同的业务应用场景需求，对敏感数据进行脱敏处理，防止数据泄露保障，满足公司敏感数据的保护及合规监管的安全需求。

数据接口安全

移动云利用网络流量采集模块，实现接口数据实时监控，基于行为分析策略，排查各类涉及数据外发的业务接口，做到全量接口数据安全管控。移动云面向互联网及合作方开放的数据接口具备接口认证鉴权与安全监控能力，能够限制违规设备接入，对接口调用进行必要的自动监控和处理，对涉及个人信息和重要数据的传输接口实施调用审批，定期开展接口日志审计。

数据操作审计

移动云通过部署多套数据库审计系统，实现对数据库操作行为全面、准确的监控审计。利用数据操作行为实时收集分析，实现操作审计的集中化管理。移动云结合实际业务场景，通过设置数据库操作和数据访问审计规则，能够精确识别高危操作和异常访问数据量等行为，提升数据操作风险识别能力。集中化收集汇总数据操作日志，采用人工智能算法对风险行为进行监控报警，实现通过短信、邮件形式对数据操作风险进行通知。

数据防泄漏

移动云实现资源池数据防泄漏能力全覆盖，实现移动云平台数据交互过程中的敏感数据泄露风险的监控和防护，通过在网络核心区域以及数据库前置网络设备部署数据防泄漏监控探针，进行实时数据的分析采集，实现数据泄露实时预警拦截，防范数据泄露风险。

数据安全态势

移动云数据安全平台具备数据安全态势感知监测模块，实现数据的实时态势监控。平台收集数据流量，提取关键数据要素对象，将针对数据分布情况、访问热度、流向IP、流向用户、访问结果统计进行综合分析，形成数据画像，实现对数据风险的主动发现、精准定位、智能研判、快速处置、严格审计，完成对数据安全保护工作的闭环处置流程。通过数据安全态势地图对数据分析、操作行为下钻、数据流向情况、异常告警等进行分别展示，实现以数据安全全生命周期管理为核心，采用多维度量指标，精准描述数据安全的实时风险及整体状况。

移动云以法律法规和云安全技术规范的合规遵从为基础，在云安全规划、建设和运营全生命周期流程中，满足国家、行业在法律法规政策方面的数据安全监管要求

移动云基于云上的数据安全保护分为三个阶段：上云阶段数据保护、云中阶段数据保护、下云阶段数据保护。移动云的云上数据安全从管理和技术两方面入手，进行全面、系统的建设，实现云上数据安全目标。在云上数据的每一个阶段，都有相应的安全管理制度以及安全技术保障。

上云阶段数据保护

移动云结合客户的实际业务现状以及系统需求，为客户定制提供一站式的系统迁移解决方案，对整个迁移过程全程闭环安全管控，保证迁移工作的安全、高效完成。云服务客户可以按需要选择额外的数据保护措施。

云中阶段数据保护

首先，移动云平台数据安全遵循国家相关数据安全的要求，机房以及云计算服务器及运行关键业务和数据的物理设备位于中国境内。云平台支持对存储的数据进行完整性保护，并设置访问控制权限。移动云提供数据加解密服务产品，对云服务客户的密钥等认证凭证进行加密保护，密钥由云服务客户自行管理，从而确保移动云或任何第三方无法对云服务客户的数据进行解密。云服务数据存在若干个可用的副本，支持本地及异地数据备份与恢复功能，支持提供基于策略的自动备份与手动触发备份。

其次，移动云平台支持对数据访问进行身份认证，强制使用强密码以及提供多因素认证进行二次身份鉴别。云平台支持对数据的操作设置权限，遵循最小权限原则，为不同安全等级的数据设置不同访问权限。云平台支持为云服务客户提供日志管理服务，支持将监控数据、日志数据安全传输到存储服务中进行持久化存储等，确保数据操作可以被追溯和审查。

最后，对于云上数据传输，移动云数据传输安全提供基于HTTPS等安全协议的传输通道，结合加密、脱敏、物理封装等防护手段，保障数据的机密性和完整性，以防止未经授权的用户窃听和篡改数据，保护数据传输安全。为了保障云端数据在传输过程中的安全，移动云提供虚拟专用网络VPN，在公用网络上建立专用网络，进行加密通讯，实现数据的传输安全。云服务客户根据自身业务安全需求选择合适的数据传输方式与传输协议（如HTTPS、SSH等）

下云阶段数据保护

数据下云过程中，移动云提供通用的标准格式来备份迁出云服务客户数据，确保数据的可移植性和可操作性。大部分情况下，云服务客户可以通过控制台或者移动云提供的工具自行完成数据迁移下云的过程，而无需移动云的额外协助。作为云服务提供商，移动云会严格按照服务协议中的条款在数据下云之后及时处置。当云服务客户的移动云服务终止后，移动云将遵循严格的逻辑擦除或物理擦除方式，对云服务客户的所有数据进行删除。

移动云上云服务客户数据的控制权完全归云服务客户所持有。除非以下情况，移动云内部员工不会主动触碰任何云服务客户数据：

- （一）因提供服务或排错的需要，并经过云服务客户明确授权；
- （二）国家或地方政府部门关于犯罪事件的调查等符合国家法律法规的情况。移动云遵循权限最小化原则，只在云服务客户授权范围内赋予内部员工为提供相应云服务所必需的最小的操作权限，非授权范围内的数据活动必须进行严格的授权审批。移动云从内部管理制度和自动化、工具化的运维管理平台层面双管齐下，杜绝云服务客户数据非授权访问情况的发生。

个人信息隐私保护

在互联网日益渗透和相关技术日新月异的背景下，全面加强个人信息保护，防范企业非法、过度收集个人信息，已越来越迫切。随着数据安全法、个人信息保护法陆续出台，国家对个人信息保护越来越重视。2021年《中华人民共和国个人信息保护法》公布施行，对于个人信息层面的数据保护工作提出了明确的安全要求。为进一步落实个人信息保护法相关要求，强化个人信息安全责任，移动云致力于保护云服务客户的个人信息，保证云服务客户对所有提供给移动云的个人信息拥有控制权。同时，移动云积极响应国家监管部门对企业承担个人信息保护责任的号召，持续完善内部的个人信息管理体系。

移动云通过大量权威机构的认证证明个人信息保护能力/数据安全保护能力达到较高水平，详细信息请见 ISO 27018、可信云服务数据保护认证等。

移动云的隐私权政策可以在移动云官网查看，详细信息请参见移动云隐私权政策（<https://ecloud.10086.cn/op-help-center/doc/article/27419>）

13 移动云安全白皮书-产品安全

移动云运营管理平台

移动云运营管理平台（BC-OP）为企业和个人用户提供丰富、可靠、安全的IaaS、PaaS和SaaS服务能力，致力于打造优质、快捷高效的自服务用户体验，让计算、存储、网络等成为触手可及的公共资源。

产品安全保障：数据交互与API安全、账号安全

虚拟网络产品

虚拟网络产品支持云服务客户自定义网络、子网、虚拟网卡，提供DHCP服务，支持vlan/vxlan隔离。虚拟网络产品提供虚拟网络功能，产品包括虚拟私有云、弹性负载均衡、弹性公网IP、共享带宽、IPSECVPN、SSL VPN、对等连接、NAT网关等。

产品安全保障：安全隔离、异常流量监测、权限控制、加密通信

13 移动云安全白皮书-产品安全

存储产品

对象存储

对象存储 EOS（Elastic Object Storage）是移动云为客户提供的一种海量空间的存储产品，具备高性能、高可靠、安全、低成本等特性。

产品安全保障：传输加密、认证鉴权、访问控制、数据保护

块存储

云硬盘是为云主机、裸金属、容器提供的高可靠、高并发、低时延的块存储产品。云硬盘基于分布式存储系统实现，通过多副本的强一致性保证数据可靠性。

产品安全保障：数据存储与保护、数据销毁、云硬盘快照、云硬盘备份与恢复、云硬盘加密

文件存储

移动云文件存储是面向云主机、裸金属、容器服务等云服务器的一种分布式文件系统服务，提供标准 NFS/SMB 的文件访问协议。

产品安全保障：访问控制、数据保护、文件系统备份与恢复

13 移动云安全白皮书-产品安全

弹性计算产品

移动云主机

移动云主机是一种按需获取的云端服务器，为云服务客户提供高可靠、弹性扩展的计算资源服务。

产品安全保障：云服务客户隔离、日志审计、安全组、SSH密钥对、云主机备份

FPGA云主机

FPGA云主机，是提供FPGA硬件加速资源的云主机。云服务客户可创建自定义的专用硬件加速器，可以将工作负载部署在FPGA加速硬件上。

产品安全保障：设备安全、镜像合规、资源隔离

裸金属服务器

FPGA云主机，是提供FPGA硬件加速资源的云主机。云服务客户可创建自定义的专用硬件加速器，可以将工作负载部署在FPGA加速硬件上。

产品安全保障：计算独享，快速交付、安全隔离，稳定可靠、全面掌控，随心部署、无缝加密，自主可控

13 移动云安全白皮书-产品安全

弹性计算产品

专属宿主机

专属宿主机DDH（DedicatedHost）提供专属的计算资源，独享所有的vCPU与内存资源，与其他租户云主机物理隔离，消除资源争抢。

产品安全保障：资源专属、安全合规、高可用性

容器服务

容器服务为云服务客户提供了多种类型不同版本的集群，针对云服务客户应用部署的不同场景，可新建或者纳管不同类型的主机。

产品安全保障：网络隔离、数据安全、访问控制、过程记录、开放API

容器镜像服务

移动云容器镜像服务CIS（Container Image Service）是一种简单易用、安全可靠的云原生资产管理服务，提供容器镜像、HelmChart等符合OCI标准的云原生制品的全生命周期管理。

产品安全保障：独享实例存储与镜像隔离、镜像安全扫描、安全认证、存储与通信加密

13 移动云安全白皮书-产品安全

CDN

CDN（Content Delivery Network）通过遍布全国的缓存边缘节点、内部专用线路以及完善的网络路由调度机制为用户自动选择最佳网络访问路径。

产品安全保障：防篡改、防盗链、IP黑白名单

边缘计算

移动云边缘智能服务平台（EISP）是移动云边缘计算统一的集中协同管控平台，可满足在广域/局域场景下的边缘资源纳管、边缘容器、云边协同能力覆盖。

产品安全保障：完善的加密与鉴权机制、数据安全、日志留存、业务系统加固

MySQL数据库

移动云MySQL数据库是一种安全可靠、弹性伸缩、轻量运维、开箱即用的在线数据库服务，旨在让云服务客户腾出更多时间专注于应用开发。

产品安全保障：账号管理、加密管理、数据备份与恢复、安全审计

13 移动云安全白皮书-产品安全

云原生大数据分析

移动云原生大数据分析LakeHouse是提供一站式的流处理、批处理、交互式分析的Serverless融合大数据处理分析服务，企业使用标准SQL即可完成云上多数数据源的分析计算。

产品安全保障：数据安全、权限管控、访问安全、任务监控、日志审计

云监控

云监控是一项针对移动云资源进行监控和告警的服务。云监控直观展示云主机、云硬盘、云存储等云资源的使用情况、性能和运行状况，以及针对指标设置告警。通过全方位的监控与告警服务。

产品安全保障：安全认证、数据加密、版本管理

云日志

云日志服务提供云服务客户级别的日志采集、实时搜索、关键字告警、日志存储、归档服务，帮助云服务客户利用实时日志进行线上业务维护。

产品安全保障：安全认证、加密与脱敏、安全校验

MQTT

消息队列MQTT主要承担移动端连接接入、连接管理、数据转发等工作，其作用类似于一个无限扩展能力的连接网关，后端数据持久化和消息存储可以搭配移动云其他消息队列产品。

产品安全保障：传输加密、认证鉴权、访问控制、资源监控、资源隔离

RabbitMQ

消息队列 RabbitMQ 是移动云自研的一款支持AMQP协议，兼容开源RabbitMQ客户端，提供高性能、低延迟、安全可靠的分布式消息服务的消息队列产品。

产品安全保障：认证鉴权、访问控制、资源监控、资源隔离

RocketMQ

消息队列RocketMQ是移动云为客户提供的高性能、高可靠消息中间件产品。具备“普通消息、事务消息、定时延迟消息、顺序消息”等多种消息类型。。

产品安全保障：传输加密、认证鉴权、访问控制、资源监控、资源隔离

Kafka

消息队列 **Kafka** 是一种分布式、高可靠、全托管的云端消息队列服务，同时支持流式和批量数据处理，广泛应用于日志收集、流计算处理、数据中转等大数据应用场景。

产品安全保障：数据安全、访问控制、独享实例

Pulsar

消息队列 **Pulsar** 是移动云基于开源 **Apache Pulsar** 构建的企业级消息中间件服务，可应用于金融、物联网、互联网等领域，适用于计费统计、数据同步、异步解耦、流数据处理等场景。

产品安全保障：数据安全、访问控制、权限控制

用户基础安全

DDoS防护

针对DDoS（分布式拒绝服务）攻击来提供防护的专业安全产品，能够对云服务客户的流量进行实时采集和分析，对异常流量进行跟踪、记录，实现对攻击流量的快速过滤，有效保护云服务客户业务免遭攻击。同时提供专业安全报表，支持自定义告警策略，帮助云服务客户直观了解现网安全状况，及时消除安全隐患。

产品安全能力：近源抗D防护、DDoS高防、DDoS原生防护

网络ACL

云服务客户可自定义网络ACL规则，通过关联路由器，提供对云服务客户内部网络的整体安全防护。云服务客户通过定义规则，允许或禁止流量通过。

产品安全能力：安全组与网络ACL、主机粒度的安全防护、内网防护

用户基础安全

云堡垒机

云堡垒机是移动云为用户提供的云资源安全管理平台，帮助用户更加精细地管理云上资产，实现对云上资产运维过程的事前规划、事中控制和事后审计，同时，移动云堡垒机还支持自动化运维、资产拓扑发现、工单审批等功能，帮助用户建立完善的运维管理与内控体系，建立安全、高效、可控的运维管理机制。云堡垒机提供了丰富、全面的管控功能，帮助企业解决运维过程不透明、责任认定难、管理不规范、权限混乱、控制力度不足、审计不全面等难题，同时统一管理企业信息系统资源。

产品安全能力：身份管理、角色分权、集中管控、资源改密、资源访问、全程审计、命令控制、工单

网络ACL

云服务客户可自定义网络ACL规则，通过关联路由器，提供对云服务客户内部网络的整体安全防护。云服务客户通过定义规则，允许或禁止流量通过。

产品安全能力：安全组与网络ACL、主机粒度的安全防护、内网防护

用户基础安全

态势感知

移动云态势感知产品采用先进的大数据架构，通过采集系统的网络安全数据信息，对所有安全数据进行统一处理分析，实现对网络攻击行为、安全威胁事件、日志、流量等网络安全问题的发现和告警，打造安全可监控、攻击可防护、威胁可感知、事件可控制的安全能力。

产品安全能力：主动监测、精准防护、智能分析、可视化态势

增强漏洞扫描

移动云增强漏洞扫描产品可以提供针对移动云外公网IP或者域名的安全漏洞扫描服务，以便云服务客户可以掌握其IP或者域名存在的安全漏洞情况，并提供更详细的漏洞信息和修复建议。

产品安全能力：扫描任意非移动云资产、报表展示、账号与基线扫描、漏洞管理

用户基础安全

日志审计

移动云日志审计是一款基于大数据架构的日志审计系统，针对大量分散的异构日志进行集中采集、统一管理、存储、统计分析的一体化产品，可协助企业满足等保合规要求、高效统一管理资产日志并为安全事件的事后取证提供依据。

产品安全能力：统计展示、日志管理、事件管理

云安全中心

移动云安全中心是一款提供集中化云上资产安全防护的主机类安全产品。云安全中心具备统一的资产安全状态展示，可实时对安全威胁进行识别和响应。云服务客户通过在云主机或服务器安装轻量Agent插件，即可获得漏洞检测、主机异常登录检测、暴力破解防护、基线合规检查、云平台配置检测等多种安全检测服务，全方位保护云上资产的安全并满足监管合规要求。

产品安全能力：资产集中化管理、漏洞\补丁检测与基线检查、账号安全、入侵检测与病毒防御、动态蜜罐

14 移动云安全白皮书-安全产品

用户基础安全

云原生应用安全

云原生应用安全以容器技术为基础，为云原生环境 提供全方位的安全检测与防护能力，覆盖从容器镜像、容器编排到容器运行时的全生命周期，为用户提供灵活的安全控制策略，帮助用户发现安全漏洞、病毒木马、网络流量问题，并对入侵行为进行检测和防护。

产品安全能力：镜像安全、运行时安全、微隔离、安全合规

14 移动云安全白皮书-安全产品

用户基础安全

SSL 证书管理

SSL 证书管理（SSLCertificateManager）是移动云联合全球知名数字证书服务机构，为您提供一站式证书的全生命周期管理，实现网站的可信身份认证与安全数据传输。

产品安全能力：申请与管理、多类型下载

入侵检测

入侵检测产品实时检测网络流量，监控各种网络行为，对非法的、不正常的、含攻击行为的报文能及时报警和检测，实现从事前检测、事中告警到事后取证全流程保护企业信息系统和网络架构安全

产品安全能力：入侵事件分析、入侵响应、入侵审计

业务安全

网站安全卫士

网站安全卫士基础版/高级版提供各类安全监测服务（篡改监测、敏感内容监测、挂马监测、暗链监测、钓鱼监测、域名劫持监测、平稳度监测等）；防护版对Web目录文件非法操作实时监控，防止黑客、病毒等对网页进行非法篡改和破坏，同时可有效应对SQL注入、XSS攻击、网站盗链等Web攻击，对恶意请求及时拦截。本产品为用户打造可靠、安全、高效的在线网站服务，提升网站公信力。

产品安全能力：安全监测、Web漏洞扫描、网页篡改防护、攻击防护

实人认证

实人认证产品是指依托活体检测、人脸比对等生物识别技术进行的自然人真实身份的校验服务，可为商户提供身份信息查验、人像比对、静默活体检测等能力，支撑互联网、银行、物流、电力、酒店、建筑等行业实名认证服务的落地。实人认证服务目前仅支持对拥有中华人民共和国第二代居民身份证的居民进行认证。

产品安全能力：保障设备安全、保障客户业务安全、微隔离、保障客户业务安全

业务安全

Web全栈防护

Web全栈防护一方面监测及时发现潜在的安全威胁，通过实时展示的图表直观精准地呈现当前的安全状态、分析结果以及防护效果；另一方面通过专业的应用层防护技术，在应用层安全领域（如WEB安全等）对常见的精细化、场景化的攻击做出迅速干预，特别是对于混合式且快速变化的攻击进行有效防御。

产品安全能力：**Web攻击防护**、安全态势呈现与报表管理、重保服务、高级管理

云下一代防火墙

云下一代防火墙是一款虚拟化边界网络安全防护产品，可提供互联网边界和内网VPC边界的流量管理与安全防护，具备安全访问控制、入侵防御、病毒防御、僵尸网络C2防御等能力，是网络边界防护和等保合规利器。

产品安全能力：访问控制、**Web扫描**、病毒防护、持续检测及响应、基础网络安全功能

数据安全

密钥管理

提供安全、可靠、简单易用的密钥托管服务，帮助用户集中管理密钥，保护密钥安全。密钥管理服务通过使用硬件安全模块保护密钥的安全，所有的用户密钥都由硬件安全模块中的根密钥保护，避免密钥泄露。

产品安全能力：密钥安全、安全认证、信息加密

数据库审计

数据库审计系统是一款针对数据库活动进行实时监控、安全分析和审计的数据库审计产品。它在充分吸收传统数据库审计系统优势的基础上，结合大数据安全技术，提供海量审计日志存储和高效日志检索性能，及时告警数据库高危操作和非法入侵行为，为降低企业数据资产损失，满足合规要求，提供强有力的安全保障。

产品安全能力：用户权限细粒度管理、系统监报告警和管理

数据安全

数据加密

数据加密基于国家密码局认证的硬件密码机提供弹性、安全的云上数据加解密服务。用户能够使用多种加密算法保护云上业务数据安全，也能对密钥进行安全可靠的管理，满足安全合规要求。

产品安全能力：防泄漏防篡改、安全合规、权限分离、安全认证、信息加密

敏感数据保护

数据脱敏（DataMasking），又称数据漂白、数据去隐私化或数据变形。指对某些敏感信息通过脱敏规则进行数据的变形，实现敏感隐私数据的可靠保护。这样，就可以在开发、测试和其他非生产环境以及外包环境中安全地使用脱敏后的真实数据集。静态数据脱敏系统（SDM）一般用在生产环境向测试环境导出数据，用于开发测试、数据分析、培训等，对存在敏感信息的数据进行脱敏处理，并生成一套新的业务数据，从源头避免了隐私数据的泄露，并且当数据以txt、excel等格式进行传输时，进行敏感数据发现和转发。

产品安全能力：防泄漏、保证测试、开发、应用阶段的数据有效性、完整性
保证数据维护和数据共享的安全、保证隐私数据管理的政策合规性

内容安全

移动云富媒体内容审核

移动云富媒体内容审核是一款内容安全类产品，支持视频、音频、文档、图片、文本等内容审核，精准识别多场景违法违规内容，高效防御内容风险，提高审核效率。主要提供内容检测API接口、对象存储内容检测功能，支持涉黄、涉政、涉暴恐、广告、违禁等多个场景40+种标签检测。

产品安全能力： 传输加密、认证鉴权

谢 谢



南京大學
NANJING UNIVERSITY